الوسائل المستخدمة للتعامل مع الهجمات:

1- الوقاية(): منع الهجوم قبل حدوثه.
2- الكشف(): التعرف علي الهجمات عند حدوثها او بعد وقوعها.
3- الاسترداد(): استرداد النظام او البيانات الي حالة سليمة بعد الهجوم.

ملاحظات مهمه:

هذه الإجراءات قد تخلق ثغرات جديدة.

سيكون هناك دائما ثغرة متبقية لا يمكن القضاء عليها.

الهدف هو تقليل المخاطر الي الحد الأدنى.

الإجراءات المضادة (Countermeasures)

هي الوسائل والتقنيات والإجراءات التي تستخدم للحد من التهديدات أو الثغرات أو الهجمات على النظام.

يمكن أن تشمل:

- إزالة أو منع التهديدات: منع الهجمات من الحدوث أصلاً.
- تقليل الضرر: الحد من تأثير الهجوم في حال حدوثه.
- الكشف والتقرير: التعرف على الهجمات عند وقوعها والإبلاغ عنها لتمكين اتخاذ إجراءات تصحيحية.

أنواع الإجراءات المضادة:

1 تقنية: (Technical) مثل الجدران النارية برامج مكافحة الفيروسات، التشفير.

2 إدارية: (Administrative) سياسات الأمن التدريب، إدارة الحقوق والصلاحيات.

3. فيزيائية: (Physical) حماية المعدات التحكم في الوصول إلى المرافق المراقبة بالفيديو.

الهدف النهائي للإجراءات المضادة هو تقليل المخاطر إلى الحد الأدنى ضمن القيود المتاحة، مع الاعتراف بوجود ثغرات متبقية قد تستغل.

Threat Consequences" " مصطلح

"عواقب التهديد" أو "نتائج التهديد"

المعنى التأثيرات أو الأضرار التي قد تنشأ إذا تم استغلال التهديد أو وقوعه على النظام أو المنظمة.

مثال: فقدان البيانات توقف الخدمة، أو تسرب المعلومات السرية كلها عواقب تهديدات أمنية.

في سياق أمن الحاسوب، يمكن تصنيف الهجمات والتهديدات حسب نوع الضرر الذي تحدثه على النظام أو الموارد

1. الإفشاء غير المصرح به: (Unauthorized Disclosure)

طرق حدوثه : التعرض الاعتراض، الاستدلال، التسلل.

مثال حصول شخص غير مصرح له على معلومات حساسة.

2. الخداع (Deception):

طرق حدوثه : انتحال الهوية، التزييف، الإنكار.

مثال: إرسال رسائل مزيفة لتضليل النظام أو المستخدمين.

3. التعطيل: (Disruption)

طرق حدوثه : الإعاقة الفساد العرقلة.

مثال: تعطيل النظام أو التسبب في فقدان البيانات.

4. الاستيلاء أو الانتحال (Usurpation)

طرق حدوثه : الاستيلاء غير المشروع، سوء الاستخدام.

مثال استخدام موارد النظام بطريقة غير قانونية أو غير مصرح بها.

هذه الفئات تمثل طرق مختلفة لاستغلال الثغرات والتأثير على السلامة السرية، والتوافر الموارد النظام.

صف RFC 2828 أربعة أنواع من نتائج التهديد وانواع الهجمات الناتجة عنها:

1. الإفشاء غير المصرح به - (Unauthorized Disclosure)تهديد للسرية:

- التعرض (Exposure) : يتم الكشف عن بيانات حساسة مباشرة لكيان غير مصرح له.
- الاعتراض (Interception)يصل كيان غير مصرح له إلى بيانات حساسة أثناء انتقالها.
- الاستدلال (Inference) : يحصل كيان غير مصرح له على بيانات حساسة بطريقة غير مباشرة من خلال الاستنتاج من خصائص أو آثار الاتصالات.
- التسلل:(Intrusion) بتجاوز كيان غير مصرح له حماية النظام الأمنية.

2. الخداع - (Deception)تهديد السلامة النظام أو البيانات:

- انتحال الهوية (Masquerade) يتظاهر كيان غير مصرح له بأنه كيان مصرح له.
- التزوير: (Falsification) استخدام بيانات مزيفة لخداع كيان مصرح له.
- الإنكار: (Repudiation)خداع كيان آخر عن طريق إنكار المسؤولية عن فعل معين.

3. التعطيل - (Disruption) تهديد للتوافر أو سلامة النظام:

- الإعاقة: (incapacitation)منع أو مقاطعة تشغيل النظام عن طريق تعطيل مكون من مكونات النظام.
- الفساد (Corruption)تعديل وظائف النظام أو البيانات بطريقة ضارة.
- العرقلة: (Obstruction)مقاطعة تقديم خدمات النظام عن طريق إعاقة تشغيله.

4. الاستيلاء - (Usurpation)تهديد السلامة النظام:

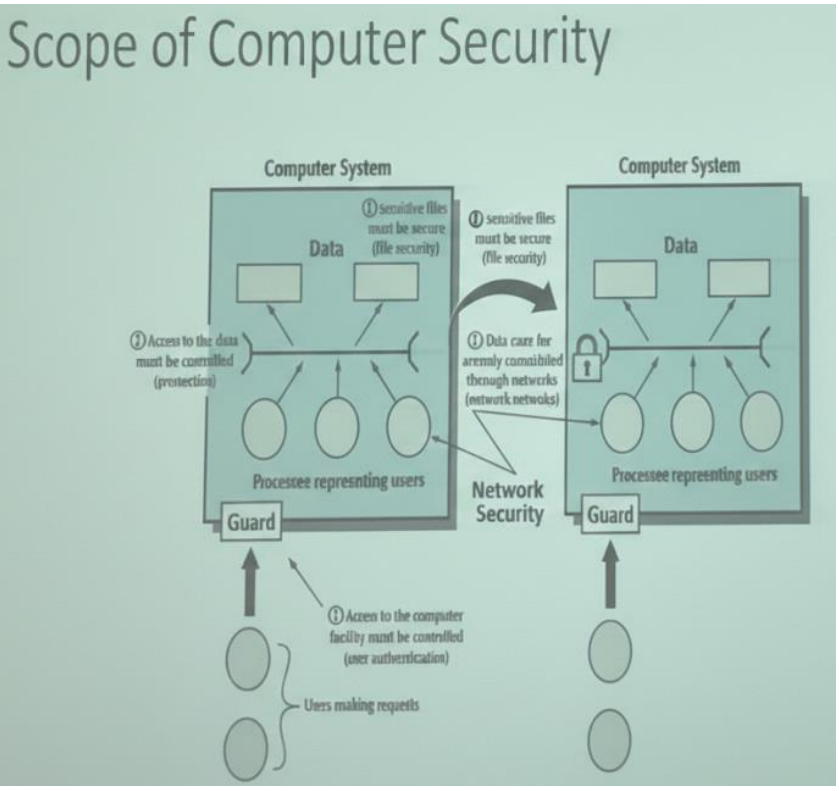
- الاستحواذ غير المشروع (Misappropriation) السيطرة غير المصرح بها على مورد من موارد النظام، منطقيا أو ماديا.
- سوء الاستخدام (Misuse) جعل النظام يؤدي وظيفة أو خدمة تضر بالأمن.

أنواع الهجمات (Attacks)	الهدف الأمني المتأثر	نوع التهديد (Threat)
- التعرض - (Exposure)الاعتراض (Interception) - الاستدلال - (Inferenc) التسلل (Intrusion)	السرية(Confidentiality)	الإفشاء غير المصرح به(Disclosure Unauthorized)
- انتحال الهوية - (Masquerade)التزوير (Falsification) الإنكار (Repudiation)	سلامة النظام أو البيانات (Integrity)	الخداع (Deception)
- الإعاقة - (Incapacitation) الفساد (Corruption)العرقلة (Obstruction)	التوافر أو سلامة النظام (Availability/Integrity)	التعطيل (Disruption)
- الاستحواذ غير المشروع(Misappropriation) سوء الاستخدام(Misuse)	سلامة النظام (Integrity)	الاستيلاء (Usurpation)

ملاحظات

- كل تهديد مرتبط بهدف أمني محدد (سرية، سلامة، توافر).
- الهجمات هي طرق استغلال الثغرات لتحقيق هذا التهديد.
- يمكن استخدام هذه الخريطة كمرجع سريع عند تحليل المخاطر أو تصميم الإجراءات المضادة.

ما ذكر، يمكن تصنيف أصول نظام الحاسوب إلى الأجهزة (Hardware) البرمجيات (Software) البيانات (Data) ، وخطوط الاتصال والشبكات.(Communication Lines and Networks) سنصف هذه الفئات باختصار وتربطها بمفاهيم السلامة / التكاملية السرية، والتوافر، كما هو موضح في الشكل



1. الأجهزة (Hardware)

- التهديد الرئيسي تهديد التوافر (Availability)
- الأجهزة في الأكثر عرضة للهجوم والأقل قابلية للتحكم الآلي.
- تشمل التهديدات الضرر العرضي والمتعمد للمعدات بالإضافة إلى السرقة.
- مثال سرقة أقراص CD-ROM و DVD قد تؤدي إلى فقدان السرية.
- الحل: الحاجة إلى إجراءات أمنية فيزيائية وإدارية للتعامل مع هذه التهديدات.

2. البرمجيات (Software)

وتشمل نظام التشغيل الأدوات المساعدة وبرامج التطبيقات.

- التهديد الأساسي الهجوم على التوافر.
- البرمجيات غالبا ما يسهل حذفها، ويمكن تعديلها أو تلفها بحيث تصبح غير صالحة للاستخدام.
- إدارة تكوين البرمجيات بعناية تساعد على الحفاظ على التوافر العالي.
- مشكلة أصعب تعديل البرمجيات (مثل الفيروسات أو الديدان) بحيث تظل تعمل ولكن بطريقة مختلفة عن السابق، وهو تهديد للسلامة التكاملية والأصالة (Integrity/Authenticity).

3. البيانات (Data)

- تشمل الملفات وأشكال البيانات الأخرى التي يتحكم فيها الأفراد أو المجموعات أو المؤسسات.
- المخاوف الأمنية المتعلقة بالبيانات واسعة، وتشمل التوافر السرية، والسلامة.
- التوافر: القلق من تدمير ملفات البيانات، سواء عن طريق الخطأ أو بشكل متعمد.
- السرية: القلق الواضح هو القراءة غير المصرح بها للملفات أو قواعد البيانات. وهناك تهديد أقل وضوحًا للسرية يتعلق بتحليل البيانات، كما يظهر في استخدام قواعد البيانات الإحصائية التي توفر معلومات ملخصة أو مجمعة.

- السلامة التكاملية: مصدر قلق رئيسي في معظم المنشآت، إذ يمكن أن تؤدي التعديلات على ملفات البيانات إلى نتائج تتراوح بين بسيطة وكارثية.

مصطلح " "Network Security Attacks

" هجمات أمن الشبكات"

المعنى: المحاولات المتعمدة لاختراق أو تعطيل الشبكات أو سرقة البيانات أو التأثير على سلامة المعلومات المتبادلة عبر الشبكة.

أمثلة: هجمات رفض الخدمة ((DoS، التنصت على البيانات ((Eavesdropping، هجمات الرجل في الوسط(Man-in-the-Middle)، والبرمجيات الخبيثة التي تستهدف الشبكات.

يمكن تصنيف الهجمات الأمنية إلى سلبية ((Passive ونشطة ((Active على النحو الآتي:

الهجمات السلبية (Passive Attacks)

تعتمد على التنصت دون التأثير على موارد النظام.

تشمل:

- كشف محتوى الرسائل (Release of Message Contents) .
- تحليل حركة المرور (Traffic Analysis).

تتميز بأنها صعبة الاكتشاف، لذلك يكون الهدف الأساسي هو منعها.

الهجمات النشطة (Active Attacks)

تتضمن تعديل البيانات أو تزويرها أو التأثير على تشغيل النظام.

تشمل:

- انتحال الهوية ((Masquerade
- . إعادة الإرسال ((Replay
- تعديل الرسائل ((Modification
- حجب الخدمة))Denial of Service

يصعب منعها بالكامل، لذلك يكون التركيز الأساسي على اكتشافها والاستجابة لها.

الخلاصة السريعة:

الهجمات السلبية <- التنصت <- المنع هو الهدف

الهجمات النشطة <- التغيير والتخريب <- الكشف هو الهدف